

(a) Marco integrativo GQM + PRAGMATIC para indicadores ISO/IEC 42001 – Ciberseguridad de IA

1. Introducción

Este marco integra el enfoque Goal–Question–Metric (GQM) con los nueve criterios PRAGMATIC para diseñar y evaluar indicadores de ciberseguridad de IA alineados con ISO/IEC 42001 y con objetivos nacionales (p.ej. Estrategia Nacional de IA, España Digital, ENS, EU AI Act). La idea es simple: empezar por los fines (por qué medimos), formular las preguntas adecuadas (qué necesitamos saber) y, solo al final, elegir las métricas (qué datos recoger), asegurándonos de que cada métrica supera un mínimo de dignidad práctica según PRAGMATIC.

GQM asegura la trazabilidad vertical desde objetivos estratégicos hasta datos técnicos. PRAGMATIC añade un filtro horizontal de calidad para que no acabemos con indicadores que son impecables en teoría pero inútiles en la práctica.

2. Recordatorio de los componentes GQM

- **Goal (Objetivo):** propósito de alto nivel, formulado en términos de mejora, control o comprensión de un aspecto de la ciberseguridad de IA, vinculado a políticas nacionales o corporativas.
- **Question (Pregunta):** cuestiones específicas que, si son respondidas, indican en qué medida se está alcanzando el objetivo.
- **Metric (Métrica):** datos concretos, cuantitativos o cualitativos, que dan respuesta a las preguntas.

La regla de oro: cada métrica debe responder a una o varias preguntas claras; cada pregunta debe estar asociada a uno o varios objetivos explícitos.

3. Recordatorio de los criterios PRAGMATIC

Para cada métrica se evalúan los criterios PRAGMATIC en una escala simple (p.ej. 0–3: bajo, medio, alto):

- **P – Predictivo:** ¿La métrica ayuda a anticipar problemas o resultados futuros, no sólo a describir el pasado?
- **R – Relevante:** ¿Está claramente relacionada con los objetivos y riesgos clave de IA y ciberseguridad?
- **A – Accionable:** ¿Puede desencadenar decisiones o acciones concretas, con umbrales razonables?
- **G – Genuino:** ¿Refleja la realidad sin incentivos fuertes para manipularla o maquillarla?
- **M – Significativo (Meaningful):** ¿Es comprensible para las partes interesadas clave (no sólo para especialistas)?
- **P – Preciso (Precise):** ¿Está bien definida, con método de cálculo claro y reproducible?
- **T – Oportuno (Timely):** ¿Puede obtenerse con la frecuencia necesaria para ser útil?
- **I – Independiente:** ¿No es redundante respecto a otras métricas ni excesivamente dependiente de un único sistema o proveedor?
- **C – Rentable (Cost-effective):** ¿El coste de recopilarla y mantenerla es razonable respecto a su valor?

4. Ámbitos de aplicación del marco

El marco se aplica a los principales grupos de indicadores identificados en el informe ISO 42001:

1. Superficie de exposición y control básico de IA.
2. Riesgos y vulnerabilidades específicas de IA.
3. Incidentes de seguridad relacionados con IA.
4. Monitorización continua: deriva, anomalías y abuso.
5. Seguridad de datos para IA.
6. Terceros, cadena de suministro y servicios de IA externos.
7. Gobernanza, cultura y capacidad organizativa.
8. Indicadores económicos: IGM y ROI de IA segura.

Para cada ámbito se definen objetivos (Goal), preguntas (Question) y un conjunto de métricas (Metric) evaluadas con PRAGMATIC.

5. Plantilla GQM + PRAGMATIC (para reutilizar)

Se propone la siguiente plantilla de trabajo para cada indicador:

- Objetivo G (Goal): ...
- Fuente del objetivo: estrategia nacional, política corporativa, requisito normativo (citar).
- Preguntas Q asociadas:
 - Q1: ...
 - Q2: ...
- Métricas M propuestas:
 - M1: Nombre de la métrica.
 - Definición.
 - Fórmula.
 - Unidad.
 - Frecuencia.
 - Responsable.
 - Fuentes de datos.
 - Evaluación PRAGMATIC (P, R, A, G, M, P, T, I, C).
 - M2: ...
 - Definición.
 - Fórmula.
 - Unidad.
 - Frecuencia.
 - Responsable.
 - Fuentes de datos.
 - Evaluación PRAGMATIC (P, R, A, G, M, P, T, I, C).

En los ficheros siguientes, esta plantilla se aplica sistemáticamente a los indicadores clave.